

Name	Khadija Nafale Likoro
Registration number	C11_CGRCE_17281
Course	GRC102
Submission date	18 September 2026

1. Assignment Overview

ICDFA is strengthening its information security governance and needs a coherent, workable security policy manual. This document sets out that manual in the role of an Information Security Policy Adviser. It shows how policy, standard, procedure and guideline relate to one another, defines practical security requirements, assigns ownership and accountability, aligns the requirements with recognised frameworks, and sets out a lifecycle for approval, communication, exceptions, review and continuous improvement.

2. Task 1: Establishing the Policy Governance Framework

2.1 Policy, Standard, Procedure and Guideline

Before any individual policy is written, ICDFA needs a shared understanding of what each type of governance document is for and who has authority over it.

Document type	Purpose	Authority
Policy	States what the organisation requires and why. It is high level, principle based, and rarely changes.	Approved by senior management or the ICDFA governance board. Mandatory for everyone it covers.
Standard	Sets the specific, measurable requirement that must be met to satisfy a policy, for example a minimum password length or an approved encryption algorithm.	Approved by the process or asset owner, usually the security or IT lead, under delegated policy authority.
Procedure	Describes the step by step actions staff must follow to meet a standard, for example how to raise an access request.	Owned by the operational team that performs the work, reviewed by the security function.
Guideline	Offers recommended good practice that is not mandatory, giving staff a sensible default when a procedure does not cover their situation.	Issued by subject matter experts. Advisory rather than enforceable.

2.2 Policy Hierarchy

The manual is organised so that one enterprise level policy sets the overall direction, and every topic specific policy beneath it is supported by its own standards, procedures and guidelines. The flow runs in one direction: an enterprise policy sets intent, a topic policy applies that intent to a domain such as access or cloud computing, a standard makes the requirement measurable, a procedure tells staff how to carry it out, and a guideline fills the gaps that the procedure does not reach.

Level	Example in this manual
1. Enterprise policy	Enterprise Information Security Policy
2. Topic specific policies	Acceptable Use, Access Control, Data Classification and Handling, Incident Response, Mobile Device and Endpoint Security, Cloud Security, Physical Security
3. Standards	For example an Access Control Standard fixing password length, multi factor authentication rules, and privileged account review intervals
4. Procedures	For example an Access Request and Approval Procedure, or an Incident Escalation Procedure
5. Guidelines	For example a Working Securely From Home Guideline, or a Safe Cloud Storage Habits Guideline

2.3 Policy Lifecycle

Every policy in this manual moves through the same nine stage lifecycle, so that no policy is created, changed or retired informally.

Stage	What happens
1. Drafting	The policy owner drafts the document using the mandatory structure in section 3 below.
2. Consultation	Draft is circulated to affected departments, student representatives and technical teams for comment.
3. Risk and legal review	Security and legal or compliance staff check the draft against risk appetite and Nigerian regulatory obligations.
4. Approval	The named approval authority signs off the policy before it can be published.
5. Publication	The approved policy is placed on the governance portal with a version number and effective date.
6. Communication and training	Staff, students and third parties are notified and, where required, trained on the new or changed requirement.

Stage	What happens
7. Exception management	Requests to deviate from the policy are logged, assessed and time limited as set out in section 5.
8. Review	The policy owner reviews the document at the stated interval, or sooner if an incident or audit finding requires it.
9. Revision or retirement	The policy is updated and re approved, or formally retired and archived when it is no longer needed.

2.4 Stakeholders and Responsibilities

Stakeholder	Responsibility
ICDFA Governance Board	Approves the Enterprise Information Security Policy and any policy with organisation wide impact.
Chief Information Security Officer or equivalent	Owens the policy suite, chairs the risk and legal review, and reports policy metrics to the board.
Policy owners (department or system leads)	Draft and maintain the policies under their area, and decide on exception requests within their authority.
IT and cloud operations team	Implement technical controls, maintain supporting standards, and supply compliance data for metrics.
Human resources and student affairs	Communicate policy obligations to new staff and students and support enforcement of consequences.
Internal audit or compliance function	Independently checks that policies are followed and that exceptions are properly authorised.
All staff, students, instructors and administrators	Read, acknowledge and comply with the policies that apply to their role, and report exceptions or incidents.
Third parties and vendors	Comply with the relevant policy clauses written into their contracts, particularly around data handling and cloud services.

Taken together, this framework gives ICDFA a governance structure in which every rule can be traced back to an approved policy, every requirement has a named owner, and every exception or change follows the same auditable path. That traceability is what turns a set of documents into an effective governance system rather than a pile of paperwork.

3. Task 2: The ICDFA Security Policy Manual

Each of the eight policies below follows the mandatory structure: document control details, purpose and scope, definitions, roles and responsibilities, policy statements, compliance and framework alignment, exception process, enforcement, monitoring, review and version control, and related documents. Every policy is written as an organisational rule that ICDFA could publish and enforce, not as a general essay about the topic.

3.1 Enterprise Information Security Policy

Policy owner	Chief Information Security Officer (CISO)
Approval authority	ICDFA Governance Board
Version	1.0
Effective date	1 October 2026
Next review date	1 October 2027

Purpose and scope

This policy states ICDFA's overall commitment to protecting the confidentiality, integrity and availability of its academic, research and administrative information. It applies to every member of staff, every student, every instructor, every contractor and every system, whether on campus, in the cloud or accessed remotely.

Definitions

- Information asset: any data, system, device or service that holds or processes ICDFA information.
- Information security: the practice of protecting information assets from unauthorised access, disclosure, alteration or loss.

Roles and responsibilities

- The Governance Board sets risk appetite and approves this policy and any major change to it.
- The CISO is accountable for the design, implementation and performance of the whole security programme.
- Department and system owners are accountable for security within their own area.
- Every individual covered by this policy is responsible for using ICDFA information and systems appropriately and for reporting concerns promptly.

Policy statements

- ICDFA will maintain a documented set of security policies covering access, data, incident response, mobile devices, cloud services and physical security, all of which sit beneath this enterprise policy.
- Security requirements will be built into new systems, services and academic platforms from the design stage rather than added afterward.
- Risk will be assessed at least annually and whenever a significant change is planned, with results reported to the Governance Board.
- Every member of staff and every student will complete security awareness training appropriate to their role before being granted access to ICDFA systems.
- Security incidents will be reported, investigated and learned from in line with the Incident Response Policy.
- Compliance with this policy suite is a condition of using ICDFA systems and of continued enrolment or employment.

Compliance and framework alignment

This policy establishes the governance foundation referenced throughout the ISO IEC 27001 2022 control set, particularly the organisational controls in clause 5, and supports the Govern function of the NIST Cybersecurity Framework 2.0. Where a Nigerian legal obligation applies, for example under the Nigeria Data Protection Act 2023, this policy is the anchor point from which that obligation is carried down into the relevant topic specific policy.

Exception process

A request to deviate from any requirement in the policy suite must be submitted in writing to the relevant policy owner, include the business or academic reason and a proposed compensating control, and be time limited with a fixed expiry date. Enterprise level exceptions require CISO approval, and any exception with organisation wide impact is escalated to the Governance Board.

Enforcement

Non compliance may result in suspension of system access, disciplinary action under ICDFA staff or student conduct rules, and in serious cases termination of employment, expulsion or contract termination. Deliberate or repeated breaches will be treated more severely than isolated, accidental ones.

Monitoring and verification

The CISO will report a security posture summary to the Governance Board at least twice a year, drawing on the metrics defined in section 5 of this manual and on the findings of internal and external audits.

Review and version control

This policy is reviewed annually by the CISO and re approved by the Governance Board, or sooner following a major incident, a significant organisational change, or a material change in the legal or regulatory environment. Version history is maintained on the governance portal.

Related standards, procedures and guidelines

- Acceptable Use Policy
- Access Control Policy
- Data Classification and Handling Policy
- Incident Response Policy
- Mobile Device and Endpoint Security Policy
- Cloud Security Policy
- Physical Security Policy

3.2 Acceptable Use Policy

Policy owner	IT Services Manager
Approval authority	CISO
Version	1.0
Effective date	1 October 2026
Next review date	1 October 2027

Purpose and scope

This policy defines what counts as appropriate and prohibited use of IC DFA devices, networks, accounts, applications and other digital resources. It applies to anyone issued with an IC DFA account or device, and to anyone connecting a personal device to IC DFA networks.

Definitions

- IC DFA resource: any device, account, network connection, application or cloud service provided or licensed by IC DFA.

Roles and responsibilities

- Line managers and course instructors are responsible for making sure the people they supervise understand this policy.
- IT Services is responsible for technical enforcement, such as web filtering and account monitoring.
- Users are responsible for their own conduct on IC DFA resources and for the security of their own credentials.

Policy statements

- IC DFA resources are provided primarily for academic, research and administrative purposes. Limited, reasonable personal use is permitted provided it does not interfere with work or study, consume excessive resources, or breach any other IC DFA policy or law.
- Users must not use IC DFA resources to harass, defame or discriminate against others, to distribute malware, to attempt unauthorised access to any system, or to infringe copyright.
- Sharing of login credentials is prohibited. Each account is for the sole use of the person it was issued to.
- Installation of unapproved software on IC DFA managed devices requires prior authorisation from IT Services.
- IC DFA reserves the right to monitor use of its resources for security and compliance purposes, in a manner consistent with applicable privacy law and with reasonable notice to users.
- Use of IC DFA resources for commercial activity unrelated to IC DFA business is prohibited without written approval.

Compliance and framework alignment

This policy supports the Protect function of the NIST Cybersecurity Framework 2.0 and the acceptable use elements of ISO IEC 27001 2022 Annex A control 5.10 on acceptable use of information and associated assets. Monitoring activity described here is carried out with reference to applicable Nigerian privacy law.

Exception process

A department wishing to permit a use that would otherwise breach this policy, for example installing specialist research software that falls outside the approved list, must obtain written sign off from IT Services and record the exception with a review date no longer than twelve months away.

Enforcement

Breach of this policy may lead to withdrawal of access, disciplinary proceedings, and referral to law enforcement where the conduct is criminal, such as distribution of illegal content.

Monitoring and verification

IT Services will review network and system logs on a risk based sample, and will investigate specific alerts such as unusual data transfer volumes or repeated failed logins.

Review and version control

This policy is reviewed annually by the IT Services Manager and approved by the CISO, or sooner in response to new categories of misuse observed in practice.

Related standards, procedures and guidelines

- Enterprise Information Security Policy
- Access Control Policy
- Mobile Device and Endpoint Security Policy

3.3 Access Control Policy

Policy owner	IT Services Manager
Approval authority	CISO
Version	1.0
Effective date	1 October 2026
Next review date	1 October 2027

Purpose and scope

This policy defines how identity, authentication, authorisation, privileged access, account lifecycle and access review are managed across ICDFA systems. It applies to every account holder and to every system that stores or processes ICDFA information.

Definitions

- Least privilege: giving an account only the access it needs to do its job, and no more.
- Privileged account: an account with administrative rights over a system or a significant part of it.

Roles and responsibilities

- IT Services provisions, modifies and removes accounts on request from an authorised approver.
- Department and system owners approve access requests for resources under their control and confirm access reviews on schedule.
- The CISO owns this policy and approves any exception involving privileged access.

Policy statements

- Access to any ICDFA system must be requested formally, approved by the relevant resource owner, and granted on the principle of least privilege.
- Every account must be uniquely identifiable to one person. Shared or generic accounts are not permitted except for specific, documented service accounts approved by IT Services.
- Multi factor authentication is mandatory for remote access, for all privileged accounts, and for access to systems holding restricted or confidential data.
- Passwords must meet the minimum length and complexity requirements set out in the supporting Access Control Standard, and must not be reused across ICDFA and personal accounts.
- Access rights must be reviewed at least every six months by the resource owner, and immediately when someone changes role or leaves ICDFA.
- Privileged access is granted only where a documented business need exists, is time limited where practical, and is logged for later review.
- All access must be revoked within one working day of an individual's departure or role change that removes the need for that access.

Compliance and framework alignment

This policy aligns with ISO IEC 27001 2022 Annex A controls 5.15 to 5.18 on access control, and with the Protect function of the NIST Cybersecurity Framework 2.0, specifically identity management and access control. Where student or staff personal data is involved, access decisions also reflect the data minimisation principle found in the Nigeria Data Protection Act 2023.

Exception process

A resource owner who needs to grant access outside the standard rules, for example a temporary broad access grant during an emergency, must submit a written exception to the CISO describing the risk, the compensating control such as enhanced logging, and an expiry date not exceeding thirty days.

Enforcement

Unauthorised access attempts, credential sharing, or failure to complete a scheduled access review may lead to suspension of the account involved and disciplinary action against the individual responsible.

Monitoring and verification

IT Services will run automated alerts for unusual login patterns and will produce a quarterly access review completion report for each department.

Review and version control

This policy is reviewed annually, or sooner if an access related incident or audit finding indicates the current controls are insufficient.

Related standards, procedures and guidelines

- Access Control Standard
- Access Request and Approval Procedure
- Enterprise Information Security Policy

3.4 Data Classification and Handling Policy

Policy owner	Data Protection Officer
Approval authority	CISO
Version	1.0
Effective date	1 October 2026
Next review date	1 October 2027

Purpose and scope

This policy defines the classification levels ICDFA uses for its information, and the handling, storage, sharing, retention and disposal rules that apply to each level. It applies to all information created, received or held by ICDFA, in any format.

Definitions

- Public: information approved for release outside ICDFA with no restriction.
- Internal: information for use within ICDFA that would cause minor harm if disclosed externally.
- Confidential: sensitive information, such as personal data or unpublished research, that would cause significant harm if disclosed.
- Restricted: highly sensitive information, such as authentication secrets or forensic case evidence, requiring the strictest controls.

Roles and responsibilities

- Every information owner is responsible for classifying the information they create and for labelling it correctly.
- The Data Protection Officer maintains this policy and advises on classification questions.
- All users are responsible for handling information according to its classification, wherever it is stored or shared.

Policy statements

- All ICDFA information must be classified into one of the four levels defined above at the point it is created or received.
- Confidential and restricted information must be encrypted in transit and at rest, and shared only through approved channels.
- Confidential and restricted information must not be stored on personal cloud accounts or removable media that has not been approved by IT Services.
- Retention periods are set for each major category of information, for example academic records, financial records and forensic case files, and information must not be kept beyond that period without a documented justification.
- Disposal of confidential or restricted information, whether digital or physical, must use a method that makes recovery impractical, such as secure wipe or cross cut shredding.
- Any sharing of confidential or restricted information with a third party requires a data sharing agreement approved by the Data Protection Officer.

Compliance and framework alignment

This policy supports ISO IEC 27001 2022 Annex A controls 5.12 to 5.14 on classification, labelling and transfer of information, and the Identify and Protect functions of the NIST Cybersecurity Framework 2.0. It is the principal mechanism by which ICDFA meets its obligations under the Nigeria Data Protection Act 2023 regarding the handling of personal data, and international requirements such as the General Data Protection Regulation are applied only where ICDFA processes data belonging to individuals located in the European Union.

Exception process

A department needing to handle confidential information in a way that departs from this policy, for example using a specific research collaboration platform outside the approved list, must obtain written approval from the Data Protection Officer, document the compensating control, and set a review date.

Enforcement

Mishandling of confidential or restricted information, including incorrect classification or unauthorised sharing, is treated as a serious matter and may lead to disciplinary action, and where personal data is involved may also trigger ICDFA's regulatory breach notification obligations.

Monitoring and verification

The Data Protection Officer will run periodic spot checks of shared drives and cloud storage for misclassified or mislabelled information, and will track disposal records for confidential and restricted material.

Review and version control

This policy is reviewed annually and whenever Nigerian data protection law or ICDDFA's data processing activities change materially.

Related standards, procedures and guidelines

- Data Retention and Disposal Standard
- Cloud Security Policy
- Incident Response Policy

3.5 Incident Response Policy

Policy owner	CISO
Approval authority	ICDFA Governance Board
Version	1.0
Effective date	1 October 2026
Next review date	1 October 2027

Purpose and scope

This policy defines how ICDFA detects, reports, escalates, investigates and recovers from information security incidents, and how evidence is preserved for possible disciplinary, legal or forensic purposes. It applies to any event that threatens the confidentiality, integrity or availability of ICDFA information or systems.

Definitions

- Security incident: any confirmed or suspected event that compromises the confidentiality, integrity or availability of ICDFA information or systems.
- Chain of custody: the documented, unbroken record of who handled a piece of evidence and when.

Roles and responsibilities

- Every user must report a suspected incident to IT Services or the CISO as soon as it is noticed.
- The CISO leads the incident response team and decides on containment and escalation actions.
- IT Services carries out technical containment, evidence preservation and recovery actions.
- Senior management and, where required, the Governance Board are informed of incidents above an agreed severity threshold.

Policy statements

- Suspected incidents must be reported within one hour of discovery, using the incident reporting channel published on the governance portal.
- Incidents are triaged into severity levels, with critical incidents receiving an initial response within thirty minutes at any time of day.
- Evidence relevant to an incident, including logs, images and physical devices, must be preserved and handled under a documented chain of custody, particularly where the incident may involve digital forensics or legal proceedings.
- Affected individuals, and where required by law the data protection regulator, must be notified of a personal data breach within the statutory timeframe.
- A post incident review must be completed within ten working days of closure, identifying root cause and corrective actions.
- Communication about an ongoing incident, internally and externally, must be coordinated through the CISO to avoid inconsistent or premature disclosure.

Compliance and framework alignment

This policy aligns with ISO IEC 27001 2022 Annex A controls 5.24 to 5.28 on incident management, and directly supports the Respond and Recover functions of the NIST Cybersecurity Framework 2.0. Breach notification timelines reflect the requirements of the Nigeria Data Protection Act 2023.

Exception process

Where following the standard escalation path is impractical during an active incident, for example when normal approval channels are unavailable, the CISO may authorise an immediate deviation and must document the reason and confirm it with the Governance Board within five working days.

Enforcement

Failure to report a known or suspected incident promptly is itself treated as a policy breach and may result in disciplinary action, independent of any consequence arising from the incident itself.

Monitoring and verification

The CISO will track time to detect, time to contain and time to close for every incident, and will report trends to the Governance Board alongside the metrics in section 5 of this manual.

Review and version control

This policy is reviewed annually and immediately after any major incident, to incorporate lessons learned.

Related standards, procedures and guidelines

- Incident Escalation Procedure
- Digital Forensics and Evidence Handling Guideline
- Data Classification and Handling Policy

3.6 Mobile Device and Endpoint Security Policy

Policy owner	IT Services Manager
Approval authority	CISO
Version	1.0
Effective date	1 October 2026
Next review date	1 October 2027

Purpose and scope

This policy defines the minimum security requirements for laptops, desktops, tablets and phones that access IC DFA resources, whether the device is owned by IC DFA or is a personal device used under a bring your own device arrangement.

Definitions

- Endpoint: any laptop, desktop, tablet or phone used to access IC DFA information or systems.
- Mobile device management: software used by IT Services to enforce security settings on endpoints.

Roles and responsibilities

- IT Services configures and maintains security settings on IC DFA owned endpoints and manages enrolment of personal devices.
- Users are responsible for keeping their endpoint secure day to day, including not disabling security controls and reporting loss or theft immediately.

Policy statements

- Every endpoint accessing IC DFA resources must run a supported, patched operating system and up to date endpoint protection software.
- Full disk encryption is mandatory on all laptops and mobile devices that hold or can access confidential or restricted information.
- A personal device may only access IC DFA email or systems after enrolling in IC DFA's mobile device management solution and accepting the associated terms.
- Loss or theft of any endpoint used to access IC DFA resources must be reported to IT Services within four hours so remote wipe or account suspension can be applied.
- Jailbroken, rooted or otherwise tampered devices must not be used to access IC DFA resources.
- Automatic screen locking after a short period of inactivity is mandatory on all endpoints.

Compliance and framework alignment

This policy supports ISO IEC 27001 2022 Annex A controls 6.7 and 8.1 on remote working and endpoint devices, and the Protect function of the NIST Cybersecurity Framework 2.0. Encryption requirements also help satisfy the security safeguard expectations of the Nigeria Data Protection Act 2023.

Exception process

A user needing an exception, for example continued use of an older device pending replacement, must obtain written approval from IT Services, accept any compensating control such as restricted access, and agree a replacement date.

Enforcement

An endpoint found not to meet this policy may be disconnected from IC DFA systems until it is brought into compliance, and repeated non compliance may result in withdrawal of remote access privileges.

Monitoring and verification

IT Services will run automated compliance checks through the mobile device management platform and will report the percentage of compliant endpoints monthly.

Review and version control

This policy is reviewed annually and whenever a new class of device or significant new threat, such as a widespread mobile malware campaign, requires an update.

Related standards, procedures and guidelines

- Acceptable Use Policy
- Access Control Policy
- Working Securely From Home Guideline

3.7 Cloud Security Policy

Policy owner	IT Services Manager
Approval authority	CISO
Version	1.0
Effective date	1 October 2026
Next review date	1 October 2027

Purpose and scope

This policy defines the requirements for using cloud services at ICDFA, including approval of new services, configuration standards, identity and logging requirements, data protection, and how responsibility is shared between ICDFA and its cloud providers. It applies to any cloud service used to store, process or share ICDFA information.

Definitions

- Cloud service: any computing, storage or software service delivered by a third party over the internet.
- Shared responsibility model: the division of security duties between ICDFA and a cloud provider, which varies by service type.

Roles and responsibilities

- IT Services maintains the list of approved cloud services and reviews new requests.
- Department heads are responsible for ensuring staff and students use only approved cloud services for ICDFA information.
- The CISO approves any cloud service that will hold confidential or restricted information.

Policy statements

- ICDFA information may only be stored or processed in a cloud service that appears on the approved service list or has been individually approved by IT Services.
- Before a new cloud service is approved, IT Services must confirm its security certifications, data location, and the specific division of responsibility under its shared responsibility model.
- Multi factor authentication and centralised identity management must be used for all approved cloud services wherever the provider supports it.
- Logging must be enabled on cloud services holding confidential or restricted information, and logs must be retained for a period consistent with the Data Classification and Handling Policy.
- Confidential or restricted information must be encrypted before or during storage in the cloud, using keys controlled by ICDFA where the sensitivity of the data warrants it.
- Any cloud vendor handling ICDFA personal data must be assessed for third party risk and bound by a written data processing agreement before use begins.

Compliance and framework alignment

This policy aligns with ISO IEC 27001 2022 Annex A controls 5.23 on cloud services and 5.19 to 5.22 on supplier relationships, and supports the Protect and Identify functions of the NIST Cybersecurity Framework 2.0. Vendor assessment and data location requirements reflect obligations under the Nigeria Data Protection Act 2023 concerning cross border transfer of personal data.

Exception process

A department wishing to trial an unapproved cloud service, for example for a specific research project, must submit a written request to IT Services describing the data involved, obtain a risk assessment, and agree a time limited approval with a clear end date.

Enforcement

Use of an unapproved cloud service for ICDFA information is treated as a policy breach and may result in the service being blocked and disciplinary action against the individual responsible.

Monitoring and verification

IT Services will maintain a register of approved cloud services with their risk ratings, and will review vendor security certifications annually or when a provider reports a material change.

Review and version control

This policy is reviewed annually and whenever ICDFA adopts a significant new category of cloud service.

Related standards, procedures and guidelines

- Data Classification and Handling Policy

- Access Control Policy
- Third Party Risk Assessment Procedure

3.8 Physical Security Policy

Policy owner	Facilities Manager
Approval authority	CISO
Version	1.0
Effective date	1 October 2026
Next review date	1 October 2027

Purpose and scope

This policy defines the controls that protect IC DFA facilities, classrooms, laboratories, devices, media and visitors. It applies to every IC DFA building and to anyone entering IC DFA premises.

Definitions

- Restricted area: a location, such as a server room or forensics laboratory, where access is limited to named, authorised individuals.

Roles and responsibilities

- The Facilities Manager maintains physical access controls, visitor management and building security.
- Laboratory and server room owners maintain the access list for their restricted area.
- All staff, students and visitors are responsible for following site security procedures, including wearing identification where required.

Policy statements

- Access to restricted areas, including server rooms and digital forensics laboratories, is limited to named individuals whose access is reviewed at least every six months.
- Visitors must sign in, be issued a visible pass, and be accompanied in restricted areas at all times.
- Laptops, forensic devices and removable media must not be left unattended in unlocked rooms.
- CCTV monitoring is used at building entry points and in restricted areas, retained for a period set by the Data Classification and Handling Policy and used only for security purposes.
- Equipment being disposed of or transferred must have all storage media securely erased or physically destroyed before it leaves IC DFA premises.
- Environmental controls, such as fire suppression and backup power, must be maintained for server rooms and other critical infrastructure spaces.

Compliance and framework alignment

This policy aligns with ISO IEC 27001 2022 Annex A controls 7.1 to 7.14 on physical and environmental security, and supports the Protect function of the NIST Cybersecurity Framework 2.0. Secure disposal requirements also support IC DFA's obligations under the Nigeria Data Protection Act 2023 regarding secure destruction of personal data.

Exception process

A request for temporary access to a restricted area outside the normal approval process, for example for an external auditor, must be approved in advance by the relevant area owner and logged with a defined start and end time.

Enforcement

Unauthorised entry to a restricted area, propping open of secure doors, or failure to challenge an unescorted visitor will be treated as a security breach and may lead to disciplinary action.

Monitoring and verification

The Facilities Manager will review CCTV coverage and access logs for restricted areas monthly, and will report any anomalies to the CISO.

Review and version control

This policy is reviewed annually and whenever IC DFA opens a new facility or restricted area.

Related standards, procedures and guidelines

- Access Control Policy
- Data Classification and Handling Policy
- Visitor Management Procedure

4. Task 3: Framework and Control Mapping

The table below connects twelve significant requirements drawn from across the eight policies to ISO IEC 27001 2022 control themes, the relevant NIST Cybersecurity Framework 2.0 function, and any Nigerian or international legal note that applies.

Policy requirement	Business or risk objective	ISO IEC 27001 alignment	NIST CSF function	Legal or regulatory note
Least privilege access provisioning	Limit exposure from compromised accounts	5.15 to 5.18 access control	Protect	Supports data minimisation under the Nigeria Data Protection Act 2023
Multi factor authentication for privileged and remote access	Reduce risk of account takeover	8.5 secure authentication	Protect	None specific
Six monthly access reviews	Prevent accumulation of unnecessary access rights	5.18 access rights	Identify	None specific
Four level data classification scheme	Apply proportionate protection to sensitive information	5.12 classification of information	Identify	Nigeria Data Protection Act 2023 data protection principles
Encryption of confidential and restricted data	Protect data confidentiality at rest and in transit	8.24 use of cryptography	Protect	Nigeria Data Protection Act 2023 security safeguards
Secure disposal of media and equipment	Prevent data recovery from decommissioned assets	7.10 and 7.14 storage media and equipment disposal	Protect	Nigeria Data Protection Act 2023 secure destruction expectation
One hour incident reporting requirement	Enable rapid containment of security events	5.24 incident management planning	Respond	None specific
Statutory personal data breach notification	Meet legal obligation to notify affected parties and regulator	5.24 to 5.28 incident management	Respond	Nigeria Data Protection Act 2023 breach notification duty
Endpoint encryption and patching	Reduce risk from lost, stolen or compromised devices	8.1 user endpoint devices	Protect	None specific
Cloud vendor security and data location assessment	Manage third party and cross border data risk	5.19 to 5.23 supplier and cloud security	Identify	Nigeria Data Protection Act 2023 cross border transfer rules, GDPR only where EU data subjects are involved
Restricted area access control and CCTV	Protect critical infrastructure and evidence integrity	7.1 to 7.4 physical security perimeter and entry	Protect	None specific
Annual policy review cycle	Keep the policy suite current with risk and legal change	5.1 policies for information security	Govern	None specific

General Data Protection Regulation obligations are referenced only where a scenario genuinely involves the personal data of individuals located in the European Union, for example a visiting researcher or an international student. For IC DFA's core Nigerian operations, the Nigeria Data Protection Act 2023 is the primary legal reference.

5. Task 4: Implementation, Communication and Exception Management

A policy only changes behaviour if people know it exists, understand what it asks of them, and see it applied consistently. This section sets out how the manual will be rolled out and kept alive in practice.

5.1 Communication plan

- Staff and instructors: a briefing session at the start of the academic term, followed by a summary email with a link to the full manual on the governance portal.
- Students: key obligations, particularly acceptable use and data handling, are covered during orientation and reinforced through a short online module before system access is granted.
- Administrators and IT staff: a detailed technical briefing on the standards and procedures that sit beneath each policy, run by the relevant policy owner.
- Relevant third parties, such as cloud vendors and contractors: the applicable policy clauses are written into contracts and confirmed during onboarding.

5.2 Training and awareness

- General staff and students receive an annual security awareness refresher covering acceptable use, phishing recognition and incident reporting.
- IT and cloud operations staff receive deeper technical training on access control, cloud security and incident handling relevant to their duties.
- Staff handling confidential or restricted information, such as forensic examiners or the registry team, receive role specific training on data classification and secure disposal.

5.3 Leadership endorsement

The Governance Board formally endorses the policy suite at approval, and the Vice Chancellor or equivalent senior officer signs a short covering statement circulated with the manual, so that staff and students see visible commitment from the top rather than a document issued by IT alone.

5.4 Implementation sequencing

- Phase 1, months 1 to 2: publish the Enterprise Information Security Policy and Acceptable Use Policy, since these establish the baseline obligations for everyone.
- Phase 2, months 2 to 4: publish Access Control and Data Classification and Handling, and begin the access review cycle.
- Phase 3, months 4 to 6: publish Incident Response, Mobile Device and Endpoint Security, and Cloud Security, alongside the technical controls each one depends on.
- Phase 4, months 6 to 7: publish Physical Security and complete training for facilities and security staff.

5.5 Supporting tools

- A governance portal page hosting the current version of every policy, standard and procedure.
- Standard templates for access requests, exception requests and incident reports.
- Checklists for new starters, leavers and role changes covering account provisioning and access removal.
- Technical controls including mobile device management, cloud identity federation and endpoint protection software that enforce several of the policies automatically.

5.6 Exception process

Every policy in this manual uses the same exception process. A request is submitted using the standard exception template, describing the requirement it departs from, the reason, and a proposed compensating control. The relevant policy owner carries out a short risk assessment and either approves, rejects or modifies the request. Approved exceptions are logged on the exception register with a fixed expiry date, and are automatically flagged for re review when that date is reached. No exception is granted indefinitely.

5.7 Feedback and continuous improvement

Staff and students can raise feedback or report a policy that is unworkable in practice through the governance portal. The CISO reviews this feedback quarterly alongside incident trends, audit findings and the metrics in section 6, and uses it to prioritise policy updates. Significant findings are shared with the Governance Board as part of the twice yearly security posture report.

6. Task 5: Policy Effectiveness and Management Metrics

The following eight indicators let ICDFA management judge whether the policy framework is actually being followed and whether it is reducing risk, rather than simply existing on paper.

Metric	Owner	Data source	Frequency	Target	Audience	Action if missed
Policy acknowledgement rate	CISO	Governance portal acknowledgement log	Quarterly	98 percent of active accounts	Governance Board	Line managers follow up with outstanding staff and students within two weeks
Security awareness training completion	HR and Student Affairs	Learning management system	Quarterly	95 percent of required population	Governance Board, HR	Non completers are restricted to limited access until training is finished
Access review completion and exception rate	IT Services Manager	Access review records	Every six months	100 percent of reviews completed, exceptions under 5 percent	CISO	Overdue reviews are escalated to the relevant resource owner's manager
Number, age and recurrence of policy exceptions	CISO	Exception register	Monthly	No exception older than its agreed expiry, no repeat exception without a permanent fix	Governance Board	CISO opens a root cause review for any exception renewed more than once
Incidents attributable to policy non compliance	CISO	Incident register	Monthly	Downward trend quarter on quarter	Governance Board	Targeted awareness campaign on the specific failure identified
Critical audit findings and remediation status	Internal audit or compliance function	Audit reports	After each audit	All critical findings closed within ninety days	Governance Board	CISO reports weekly progress until the finding is closed
Policies reviewed within the approved cycle	CISO	Policy version log	Annually	100 percent reviewed on time	Governance Board	Overdue policy owner is required to complete review within thirty days
Endpoint and cloud compliance rate	IT Services Manager	Mobile device management and cloud security dashboards	Monthly	97 percent of endpoints and approved cloud accounts compliant	CISO	Non compliant devices or accounts are restricted until brought into compliance

7. Closing Note

This manual gives ICDFA a single, traceable governance structure. Every rule in it sits under an approved policy, every requirement has a named owner, every exception is logged and time limited, and every measure of success is tied to a real metric with a named audience. Read together, sections 2 to 6 form the complete Security Policy Manual requested in the GRC102 Week 2 assignment brief.